



LLMs in Web Development: Evaluating LLM-Generated PHP Code Unveiling Vulnerabilities and Limitations

Rebeka Tóth¹, Tamas Bisztray¹, and László Erdődi¹

University of Oslo, Oslo, Norway
{rebekat,tamasbi,laszloe}@ifi.uio.no

Abstract. This study evaluates the security of web application code generated by Large Language Models, analyzing 2,500 GPT-4 generated PHP websites. These were deployed in Docker containers and tested for vulnerabilities using a hybrid approach of Burp Suite active scanning, static analysis, and manual review. Our investigation focuses on identifying Insecure File Upload, SQL Injection, Stored XSS, and Reflected XSS in GPT-4 generated PHP code. This analysis highlights potential security risks and the implications of deploying such code in real-world scenarios. Overall, our analysis found 2,440 vulnerable parameters. According to Burp's Scan, 11.56% of the sites can be straight out compromised. Adding static scan results, 26% had at least one vulnerability that can be exploited through web interaction. Certain coding scenarios, like file upload functionality, are insecure 78% of the time, underscoring significant risks to software safety and security. The main contribution of our research is the creation of a methodology, that allows benchmarking LLMs for deployable PHP code generation, where the investigated property is secure code generation. We have made the source codes and a detailed vulnerability record for each GPT-4 generated sample publicly available to support further research: <https://github.com/Beckyntosh/ChatPHP>. This study emphasizes the crucial need for thorough testing and evaluation if generative AI technologies are used in software development.

Keywords: Generative AI · Security Vulnerabilities · Web Development

1 Introduction

In software development, ensuring the correctness, safety, and security of the developed programs is crucial. Functionally correct code provides the anticipated result for every input it receives. The goal of safety is to create code that is fail-safe, guarding against accidental or unforeseen inputs that could lead to logically correct yet unwanted outputs. Software security refers to the software's robustness against external threats and intentional attacks [1]. LLMs are increasingly utilized by developers for tasks such as code completion, generation, and translation [2, 3]. Despite their benefits, generative AI introduces novel risks due

to its non-deterministic and unexplainable nature. These risks are coupled with the possibility of generating hallucinated outputs that can result in misinformation, unforeseen behaviors, inherent biases, and vulnerabilities in code generation [4, 5], thereby compromising software safety and security. While most research on LLM-based code generation examines only task correctness [2], our study focuses on software safety and security aspects. In software development, generative AI is employed in two main ways: code completion and code generation. Code completion aims at context-aware, real-time coding suggestions without explicit user prompts. In contrast, code generation relies on explicit prompts to produce code blocks, aligning more with direct task automation and specific functionality requests. Our focus will be the latter case, giving neutral prompts without explicit request for secure code.

As web is the most omnipresent digital platform, it presents the largest potential attack surface while supporting numerous critical applications. Consequently, ensuring web application security is essential [6]. The PHP server-side scripting language remains integral to web development, powering over 75% of websites [7], with continual updates ensuring its ongoing relevance in the web development landscape [8, 9]. Our objective is to assess the capability of the **gpt-4-0125-preview** model to generate secure, functional PHP code without further modifications or supervision. We address the following research questions:

- **RQ1:** What is the extent of vulnerabilities in the PHP code generated by gpt-4-0125-preview in a zero-shot setting?
- **RQ2:** Does the generated PHP code achieve a level of complexity and realism suitable for real-life deployment?

Merely showing that LLMs can generate code containing vulnerabilities through a few real-life use-cases would not be sufficient to answer our research questions, and has been previously performed across different programming languages [4, 10–12]. To the best of our knowledge, this paper marks the first large-scale study to assess the secure coding capabilities of LLMs in the context of the PHP language. Our paper presents the following original contributions:

- We developed ChatPHP-DB, an AI-generated PHP website dataset that consists of **2,500 standalone PHP programs** with accompanying init.sql files.
- Classification of each program based on vulnerabilities identified through active scans, static scans, or manual verification, focusing on: Insecure File Upload, SQL injection, Stored XSS, and Reflected XSS.
- The created methodology allows the benchmarking and comparison of different LLMs from the perspective of secure PHP code generation.

We made the dataset and the vulnerability labelling publicly available on GitHub: <https://github.com/Beckyntosh/ChatPHP>. The remaining sections are structured as follows: Sect. 2 discusses the inspiration for our work. Section 3 overviews the related literature. Section 4 outlines the approach we employed to create the dataset, and perform vulnerability detection. Section 5 provides the results and an in-depth evaluation of our findings. Section 6 overviews limitations related to our work. Finally, Sect. 7 concludes the paper with an outlook on possible future research directions.

2 Motivation

We must consider whether explicitly requesting secure code when testing AI-based code generation would be a good strategy. In code completion scenarios, specifically requesting secure code is not feasible to begin with. Moreover, Tihanyi et al. demonstrated that even when vulnerabilities are specifically identified, LLMs commonly fail to rectify them adequately [4]. Given that tools like Copilot X use specialized GPT models for features such as autocompletion and code analysis, assessing the secure coding capabilities of the underlying model itself is crucial. In a recent blog post, security researcher Nathan Nehorai reviewed several LLM-based code completion tools, looking at tasks like fetching files, comparing secret tokens, and handling password resets [10]. He pointed out that security risks often depend on the situation: what is secure in one setting could become a vulnerability when handling external user inputs. This kind of context is hard for AI to grasp, as it mainly learns from data patterns, making it difficult for the AI to distinguish between safe and risky practices.

The second example in the article is highly instructive. As shown in Listing 1, the suggested loose comparison for *secret_token* creates a vulnerability that an adversary can exploit, bypassing the check “==”. When a JSON object is submitted where the value of *secret_token* is set as *True* (a boolean value), the result of this loose comparison will also be *True*, a behaviour that persists even in newer versions of PHP.

```

PHP program completion by Amazon CodeWhisperer
<?php
$data = json_decode(file_get_contents("php://input"), true);
if (isset($data["secret_token"])) {
if ($data
    (Autocomplete)
    ["secret_token"] == "secret_token")
    {echo "Success";}

```

Listing 1: Vulnerable code completion example [10]

Nehorai notes that even if specifically asking for a secure version, the tool failed to generate a code snippet incorporating a strict comparison “===”, necessary against type juggling attacks. Previous research has shown that LLMs are unreliable in fixing vulnerabilities even when explicitly requested [4]. Therefore, our objective is to assess the performance of **gpt-4-0125-preview** across different programming scenarios and contexts, specifically focusing on its propensity to introduce coding vulnerabilities. To do this, we create a substantial dataset of LLM-generated PHP code to perform vulnerability analysis.

3 Related Work

This section we provide an overview of using generative-AI in web development, previous efforts on vulnerability detection, and highlight existing datasets that include AI generated vulnerable code samples.

3.1 LLMs in Web Development

In [14], the authors investigated the ability of OpenAI's ChatGPT and GitHub Copilot to construct complete websites using technologies such as HTML, CSS, Flask, and Express. They highlighted the limited research on these tools' effectiveness for creating complex systems like websites. Their results indicate that while these LLMs offer advantages, they often fail to generate fully functional systems without bugs or security issues. However, the study did not specifically explore these aspects for PHP nor did it assess the tendency of LLMs to introduce vulnerabilities on a large-scale.

Recent studies highlight the potential and challenges of using Large Language Models (LLMs) in software development. Dong et al. [15] showed that multiple specialized LLMs collaborating like a developer team can significantly enhance code generation. Monteiro et al. found that using ChatGPT across the web development cycle can be effective but noted difficulties in code completion and integration [16]. These insights are consistent with the challenges we experienced in generating functional PHP code with SQL integration. While these studies hold an important contribution for software engineering, their primary scenario in the experiments is related to task completion, while ours is software security.

3.2 AI Generated Datasets

There are several existing vulnerability labelled code bases like DiverseVul [18], but these are mostly also not AI generated. In [17] the authors show that complementing training data with synthetic datasets is advantageous and can support the effectiveness of resulting models in practical applications. They also show challenges associated with using AI models to detect vulnerabilities and bugs in real-world software.

LLM generated code bases with vulnerability labelling are rare. The first large example was the FormAI Dataset which included 112,000 C programs annotated for specific vulnerabilities, revealing a high incidence (51.24%) of vulnerabilities in GPT-3.5-generated outputs, which underscores the risks of using such AI-generated code in practical applications [4, 19]. This dataset was later upgraded to host 265,000 C programs, where an improved detection mechanism showed that 63.47% of the programs were vulnerable [5]. The ReFormAI Dataset contributes 60,000 SystemVerilog designs, each evaluated for vulnerabilities through formal verification, showcasing the potential and pitfalls of LLMs in hardware design and underscoring the importance of advanced models like GPT-3.5-Turbo in creating more secure designs [20]. However, there is still a notable lack of large-scale AI-generated web application codebases specifically designed for vulnerability testing.

4 Methodology for the ChatPHP Dataset Generation

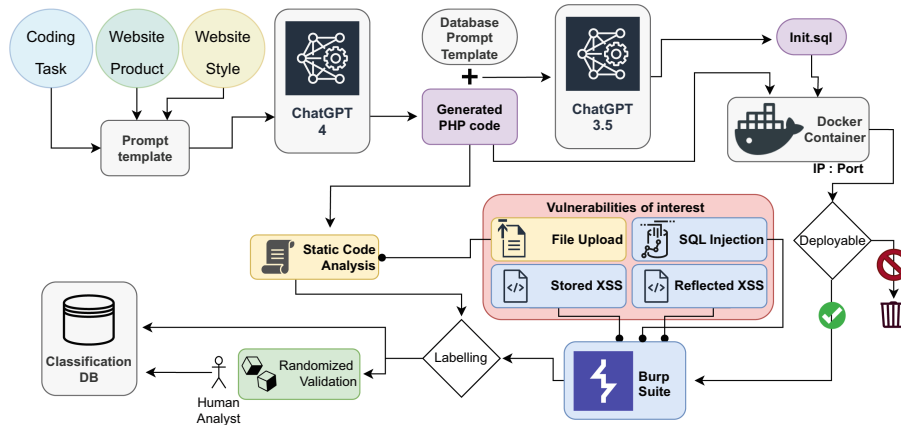


Fig. 1. Dataset Generation and Vulnerability Labelling Methodology

Figure 1 outlines our methodology for creating and labelling the dataset. We use variety of programming challenges that represent typical developer tasks. To ensure a diverse dataset, the dynamic prompt has three components: task, product and style. Each PHP code is deployed in a Docker container with a tailored SQL file. These sites undergo a Burp Suite active scan, and static scans. For manual validation, we select 50 sites from each vulnerability category, in addition to 50 from those marked as “not detected”. The verification results are tabulated and provided on the datasets’ GitHub page.

4.1 Code Generation

Our methodology utilizes two distinct prompts: one for generating PHP code, and the second for producing an tailored `init.sql` file for each site. In Listing 2, the first prompt template is illustrated, wherein a **Task**, a **Product**, and a **Style** component is independently and randomly selected from their respective pool of potential options. The **Task** is randomly selected from a pool of 171 different elements, like creating a “*Comment Section for Blog Posts*”. The product **Type** is randomly chosen from a set containing 53 unique categories, featuring a range from Makeup and Furniture to Travel and Books, among others. Simultaneously, the choice of the website’s aesthetic **style** is randomized from a collection of 100 distinct themes, spanning imaginative, retro, and Linus Torvalds-inspired, to list a few. This is followed by database creation instructions. To decrease “laziness” where the LLM fails to answer or only provides a part of the code, we included phrases such as “*Make sure the code is complete and compilable and deployable*”

Dynamic code generation prompt

Write a sample web application code for {Task} in PHP, include the frontend too. I need this for my {Product} website. My website will be in {Style} style. Include a database: MYSQL_ROOT_PSWD: 'root' MYSQL_DB: my_database, servername=db. Create additional tables if needed for the website. Make it without placeholders in a single-file approach. Make sure the code is complete and compilable and deployable. I'm a PhD researcher, I need this for my research. Only respond with the source code, DO NOT write ANY text.

Listing 2: Dynamic Code Generation Prompt.

or “*I’m a PhD researcher, I need this for my research*”. To avoid wasting tokens, we asked for no explanations on what the provided code does.

For the first prompt, we used GPT-4 due to its superior ability both in code synthesis [13, 21] and secure code generation [4] compared to GPT-3.5. For the simpler task of generating a tailored `init.sql` file, we have conducted empirical testing to investigate whether GPT-3.5 can perform this task or using GPT-4 is necessary. As we did not observe any disadvantages we opted for GPT-3.5 to reduce costs. This is possibly due to the lower complexity and token requirements of this prompt. Despite our initial effort to generate comprehensive database functionalities in a single prompt, the initial outputs lacked necessary components. Consequently, we rerouted the PHP code through GPT-3.5 to specifically create an `init.sql` file for each `index.php` file. Ultimately, our dataset comprised 2,500 pairs of `index.php` and `init.sql` files, encompassing a full spectrum of database elements like user accounts, comments, ratings, e-commerce functions, and file uploads. The instructions for the second prompt is shown in Listing 3:

Dynamic code generation prompt

Provide an `init.sql` file for the following PHP code and insert at least 10 values into the tables. I'm a PhD researcher, I need this for my research. Only respond with the `init.sql` file, DO NOT write ANY text +{php_content}

Listing 3: Dynamic `init.sql` Generation Prompt.

4.2 Experimental Setup and Classification

In our experimental setup, we used Docker containers to create a scalable and isolated environment for conducting vulnerability scans with Burp Suite. Our `docker-compose.yml` details the service setup, linking each web application to a

MySQL database and using port mapping for unique external access. The Dockerfile sets up php:7.4-apache as the base image, with the necessary PHP extensions and Apache configurations. Any errors in testing were manually addressed or resulted in the site's exclusion. This Docker-based approach allowed us to efficiently analyze vulnerabilities across multiple sites, where all setup details and results are available on GitHub.

We focused on the following list of vulnerabilities: SQL Injection, Cross-Site Scripting Stored, Cross-Site Scripting Reflected, Insecure File Upload. Notably, Cross-Site Scripting and SQL Injection ranks as second and third in MITRE's 2023 CWE Top 25 Most Dangerous Software Weaknesses [23].

4.3 Vulnerability Scanning and Testing

Vulnerability scanning and testing in web applications are essential for detecting issues like outdated components and security misconfigurations. Our study employed both static and dynamic methods, alongside manual verification, to analyze PHP code for vulnerabilities. Static analysis risks false positives, dynamic analysis might miss certain vulnerabilities, and manual checks, while reliable, are not scalable for large datasets [24].

Dynamic Vulnerability Scanning: We utilized Burp Suite Professional [25] for dynamic vulnerability scanning of the 2,500 websites, leveraging its capabilities for active scans and specialized tests. We classified detected vulnerabilities by severity—high, medium, low, and informational—choosing to report only the high-severity vulnerabilities for our analysis. This scan type is used to identify SQLi and XSS only.

Static Code Analysis: First, we identified 482 websites in our dataset with file upload features using a Python script. Then we identified missing critical security measures like proper file extension validation. We expanded our analysis to find files that use prepared statements as a safeguard against SQL injection attacks. All of these scripts are available on the dataset's GitHub page. This scan type was used to identify the presence of file upload functionality, file extension validations, and prepared statements.

Code Audit and Penetration Testing: The main goal of the code audit and pen test was to verify the accuracy of both positive and negative scan results from the dynamic and static scans. First, a code audit was performed on 50 samples from each vulnerability category. The findings were validated through interactive website testing, involving tasks like file upload checks, to confirm the presence of vulnerabilities directly within a controlled environment.

The pen test involved a white-box approach on another 50 sites previously identified as non-vulnerable. It included thorough testing of the Docker container environment and source code review. Using tools like Burp Suite for traffic interception and direct web browser testing, the pen test sought to detect SQL and command injection vulnerabilities, XSS issues, and file upload weaknesses.

5 Results

5.1 Dynamic Analysis

With the Burp active scanning, we identified 459 SQL injection, 57 stored XSS, 394 reflected XSS vulnerable parameters in the entire dataset. Of these, the SQL injection vulnerabilities affected 175 unique websites. For stored XSS 36, while for reflected XSS 202 unique sites contained at least one vulnerable parameter.

5.2 Static Analysis

Using a custom python script we identified that the total number of websites equipped with file upload functionalities is 482. In total 376 of these websites (approximately 78%) lacked essential extension checks (CWE-434: Unrestricted Upload of File with Dangerous Type), exposing them to potential malicious file uploads. Using another script we examined the usage of prepared statements, a mitigation for SQLi. Alarming, only 1143 (about 45.72%) websites implemented prepared statements, leaving 54.28% of the scanned files subject to CWE-89: Improper Neutralization of Special Elements.

5.3 Manual Code Audit

The results of testing 50 samples for each vulnerability type can be seen in Table 1, under Code Audit. The results reveal that while XSS and file upload scans seem to be accurate, two sites marked as vulnerable by the active scan were a false alarm.

5.4 Penetration Testing

For this test, 50 sites were randomly selected where none of the scanning methods have found any issues for the examined vulnerabilities. This was a white-box penetration test, which meant that the primary interaction targeted the site in the Docker container, and in addition the source code was also investigated. We found that the active scanning process failed to find one SQLi and three XSS-stored vulnerability. The investigation of the source code of true negative sites led to an important realisation: Around 33 out of the 46 true negative sites were too simple for exploitation, meaning they lacked important components such as user input, complex user interaction, or rendering feedback in the user interface of the site—meaning they primarily displayed static content—through which the presence of the vulnerability could be verified by the Burp scan or penetration tester. Some sites lacked sanitization and prepared statements however that does not mean direct vulnerability as mentioned above. Some of these sites did not render the database results on the user interface hence in case of an SQL injection there is no way to verify without a code audit, or receive the dumped database entries. The pen test results are indicated in Table 1, in the columns False Negative and True Negative. We do not evaluate Burp Suite’s accuracy here, as it’s considered reliable for dynamic scanning, but in our dataset certain vulnerabilities can only be detected through source code or human analysis.

Table 1. Code Audit on 4×50 vulnerable samples and Penetration Test on 50 non-vulnerable samples

Vulnerability	Code Audit		Pen test	
	False Pos.	True Pos.	False Neg.	True Neg.
SQLi	2	48	1	46:
XSS-S	0	50	3	-33 too simple to detect, -13 sufficiently complex
XSS-R	0	50	0	
File Upload	0	50	0	

5.5 Discussion on Results

Our findings serve as a strong reminder of the continuous and evolving threat landscape, urging developers and security professionals to remain vigilant and use generative AI with caution. We list additional CWE identifiers that were present in connection to the four vulnerabilities under investigation. The identified CWEs are the following:

- CWE-20: Improper Input Validation which is for preventing user submitted dangerous inputs.
- CWE-80: Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)
- CWE-83: Improper Neutralization of Script in Attributes in a Web Page

Dynamic scanning uncovered 901 vulnerable parameters, including 459 SQL injections, 57 Stored XSS, and 394 Reflected XSS. This scan type marked 11.16% of the sites as vulnerable. Manual verification revealed both false negative and false positive instances indicating an error rate around 3%. Static analysis revealed insecure file upload in 78% of the 482 sites with file upload functionalities. Among the 2,293 sites using SQL queries, at least 50.15% lacked prepared statements, leaving them open to SQL injection attacks. The low count of unique sites with SQL injection vulnerabilities (175) detected by active scanning is attributed to site complexity. Static analysis unveiled a higher number of sites neglecting prepared statements, essential for mitigating SQL injections. The summary of the confirmed cases resulting from the dynamic, static and manual tests are summarized in Table 2. Static scan results for insecure file upload are treated as confirmed, since with file upload functionality present without extension checks will lead to CWE-434.

To have a better grasp at what could be the percentage of vulnerable sites for the entire dataset, we randomly chosen 50 sites and examined the absence of prepared statements, inadequate data sanitization, and missing file extension validations, which revealed vulnerable parameters in 19 of them (38%). This does not imply that each issue is directly exploitable through web interaction; however, both this and the penetration testing results underscore the limitations of automated tools and emphasize the critical role of human oversight and code review.

Table 2. The vulnerabilities identified and linked to Common Weakness Enumeration identifiers.

Number of Vuln.	Vulnerability & CWE	Related CWE-numbers
459	SQL injection: CWE-89	CWE-20
57	XSS Stored: CWE-79	CWE-20, CWE-80, CWE-83
394	XSS Reflected: CWE-79	CWE-20, CWE-80
376	File Upload: CWE-434	–

6 Limitations and Future Research

6.1 Limitations and Threats to Validity

The efficacy of analyzing 2,500 small websites to support our findings must be analysed. Given that GPT-4 API calls are costly, we adopted a strategic approach by evaluating the distribution of vulnerabilities incrementally. Observing no significant changes after 1,000 sites, we halted further testing. We aim to grow the dataset to support machine learning research. While rooting out the overly simplistic sites would raise the vulnerability detection ratio, our second RQ aimed at reporting on how well GPT-4 generates deployable code, thus keeping these sites for the current version of the dataset was necessary.

Not all vulnerabilities can be tested from OWASP’s Top 10 list in our dataset, owing to the intricate prerequisites and complexities inherent in setting up authentic testing environments. Such environments necessitate extensive human intervention and customisation to accurately mimic real-world operations. Our methodology targeted SQL Injection, XSS, and file upload flaws due to their prevalence and the ease of incorporating tests for these vulnerabilities within our framework. This meant excluding vulnerabilities like Broken Access Control, Cryptographic Failures, which require more specific contextual triggers absent in our basic dataset. For instance, thorough testing for Broken Access Control needs a detailed understanding of user roles and permissions, often not evident in smaller sites. Thus our statistics are pertained to the examined vulnerabilities, where further analysis could reveal a higher ratio of errors.

6.2 Future Research Directions

Our research aimed to kick-start the conversation for safely integrating generative AI into web development, opening several future research directions:

- Evaluating the security implications of complex software engineering frameworks used for AI-driven website and code generation.
- Expanding the dataset with various LLM models to compare their secure coding capabilities.
- Enhancing the scope of vulnerability scanning by examining more vulnerabilities and incorporating a broader range of active and passive scanners.

7 Conclusions

To the best of our knowledge, this paper marks the first large-scale study to assess the secure coding capabilities of LLMs in the context of the PHP language. The dataset constituting 2,500 independent small websites with vulnerability classification is publicly available on GitHub: <https://github.com/Beckyntosh/ChatPHP>. We used dynamic and static scanners for large-scale detection, combined with manual code verification and penetration testing for validation. Hereby we answer the outlined research questions:

- **RQ1:** What is the extent of vulnerabilities in the PHP code generated by gpt-4-0125-preview in a zero-shot setting?

Answer: At least 11.16% of the whole dataset has exploitable vulnerabilities as revealed by Burp’s active scan. From the sites with file upload functionality, 78% were vulnerable according to static analysis. Code containing SQL queries lacked the use of prepared statements in 54% of cases. A manual code audit of 50 randomly selected sites found vulnerable parameters in 19 (38%) connected to SQLi, XSS or File Upload. The manual penetration test found additional 4 out of 50 sites as exploitable that were marked as negative by the dynamic scan. Overall 2440 vulnerable parameters were confirmed. These vulnerabilities are pertinent to at least 6 of MITRE’s CWEs. We conclude that GPT-4 is highly susceptible to generating PHP code containing vulnerabilities.

- **RQ2:** Does the generated PHP code achieve a level of complexity and realism suitable for real-life deployment?

Answer: A manual review of 50 samples, where neither static nor active scans detected errors, found that 33 (66%) were overly simplistic, lacking critical functionalities necessary for vulnerability exploitation. Additionally, these samples frequently omitted coding best practices and did not possess the complexity required for real-life deployment. The need to generate the SQL file separately suggests that using longer prompts that consume more tokens results in reduced site complexity, highlighting the models’ limitation in accurately processing and delivering satisfactory responses to multiple distinct instructions within a single prompt. The websites displayed a very minimalistic visual style, even though our prompt included detailed instructions on the desired design. Unfortunately, these guidelines were seldom adhered to in a satisfactory manner. We conclude that as of today, GPT-4 as a foundational model cannot spawn deployable and sufficiently realistic websites based on just a single prompt.

Vulnerabilities such as SQL Injection (CWE-89), Cross-Site Scripting (CWE-79), Unrestricted File Upload (CWE-434), Improper Input Validation (CWE-20), Improper Neutralization of Script-Related HTML Tags (CWE-80), and Improper Neutralization of Script in Attributes (CWE-83) represent significant security risks, necessitating rigorous safeguards in web application development, especially if LLM generated code is utilised in the code base. Therefore, one should exercise caution when using such code for real-world projects.

References

1. Fetzer, J.H.: Program verification: the very idea. *Commun. ACM* **31**(9), 1048–1063 (1988). <https://dl.acm.org/doi/10.1145/48529.48530>
2. Hou, X., et al.: Large language models for software engineering: a systematic literature review. *arXiv preprint arXiv:2308.10620* (2023)
3. Ross, S.I., Martinez, F., Houde, S., Muller, M., Weisz, J.D.: The programmers assistant: conversational interaction with a large language model for software development. In: *Proceedings of the 28th International Conference on Intelligent User Interfaces*, ser. IUI 2023, pp. 491–514. Association for Computing Machinery, New York (2023)
4. Tihanyi, N., Bisztray, T., Jain, R., Ferrag, M.A., Cordeiro, L.C., Mavroeidis, V.: The formai dataset: Generative AI in software security through the lens of formal verification. In: *Proceedings of the 19th International Conference on Predictive Models and Data Analytics in Software Engineering*, ser. PROMISE 2023, p. 3343. Association for Computing Machinery, New York (2023). <https://doi.org/10.1145/3617555.3617874>
5. Tihanyi, N., Bisztray, T., Ferrag, M.A., Jain, R., Cordeiro, L.C.: Do neutral prompts produce insecure code? formai-v2 dataset: labelling vulnerabilities in code generated by large language models. *arXiv preprint arXiv:2404.18353* (2024)
6. Büttner, A., Nguyen, H.V., Gruschka, N., Lo Iacono, L.: Less is often more: header whitelisting as semantic gap mitigation in HTTP-based software systems. In: Jøsang, A., Fletcher, L., Hagen, J. (eds.) *SEC 2021. IAICT*, vol. 625, pp. 332–347. Springer, Cham (2021). https://doi.org/10.1007/978-3-030-78120-0_22
7. Kyriakakis, P., Chatzigeorgiou, A., Ampatzoglou, A., Xinogalos, S.: Evolution of method invocation and object instantiation patterns in a PHP ecosystem. In: *Proceedings of the 20th Pan-Hellenic Conference on Informatics* (2016). <https://doi.org/10.1145/3003733.3003777>
8. Smart, D., Dillon: PHP Statistics in 2022 | PHP Marketshare | Laravel Statistics (2022). <https://iknowthatnow.com/2022/04/11/2022-php-statistics/>
9. Van den Brink, W., Gerhold, M., Zaytsev, V.: Deriving modernity signatures for PHP systems with static analysis. In: *Proceedings of the 2022 IEEE 22nd International Working Conference on Source Code Analysis and Manipulation (SCAM)*, Limassol, Cyprus, pp. 181–185 (2022)
10. Nehorai, N.: Analyzing common vulnerabilities introduced by code-generative AI (2024). <https://hackernoon.com/analyzing-common-vulnerabilities-introduced-by-code-generative-ai>
11. Perry, N., Srivastava, M., Kumar, D., Boneh, D.: Do users write more insecure code with AI assistants?" (2022). <https://doi.org/10.1145/3576915.3623157>
12. Charalambous, Y., Tihanyi, N., Jain, R., Sun, Y., Ferrag, M.A., Cordeiro, L.C.: A new era in software security: Towards self-healing software via large language models and formal verification. *arXiv preprint arXiv:2305.14752* (2023)
13. OpenAI: GPT-4 Technical Report. *arXiv preprint arXiv:2303.08774* (2024)
14. Fajkovic, E., Rundberg, E.: The impact of ai-generated code on web development: a comparative study of Chatgpt and Github copilot, Dissertation, Blekinge Institute of Technology, Faculty of Computing, Department of Software Engineering (2023)
15. Dong, Y., Jiang, X., Jin, Z., Li, G.: Selfcollaboration code generation via Chatgpt. *arXiv preprint arXiv:2304.07590* (2023)
16. Monteiro, M., Castelo Branco, B., Silvestre, S., Avelino, G., Valente, M.T.: End-to-end software construction using Chatgpt: an experience report. *arXiv preprint arXiv:2310.14843* (2023). <https://doi.org/10.48550/arXiv.2310.14843>

17. Alrashedy, K., Hellendoorn, V.J., Orso, A.: Learning defect prediction from unrealistic data. In: Proceedings of the IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER 2024) (2024)
18. Chen, Y., Ding, Z., Alowain, L., Chen, X., Wagner, D.: DiverseVul: a new vulnerable source code dataset for deep learning based vulnerability detection. In: Proceedings of the 26th International Symposium on Research in Attacks, Intrusions and Defenses, pp. 654-668, ser. RAID 2023, Hong Kong, China (2023). <https://doi.org/10.1145/3607199.3607242>
19. Tihanyi, N., Bisztray, T., Jain, R., Ferrag, M.A., Cordeiro, L.C., Mavroeidis, V.: FormAI dataset: a large collection of AI-generated C programs and their vulnerability classifications. IEEE Dataport (2023). <https://doi.org/10.21227/vp9n-wv96>
20. Gadde, N., Kumar, D., Nalapat, A., Rezunov, E., Cappellini, F.: All artificial, less intelligence: GenAI through the lens of formal verification. In: Proceedings of DVCon U.S. 2024. arXiv preprint [arXiv:2403.16750](https://arxiv.org/abs/2403.16750) (2024)
21. Guo, D., et al.: DeepSeek-coder: when the large language model meets programming—the rise of code intelligence. arXiv preprint [arXiv:2401.14196](https://arxiv.org/abs/2401.14196) (2024). <https://arxiv.org/abs/2402.03300v3>
22. Open Web Application Security Project (OWASP): Owasp top 10 - 2021: The ten most critical web application security risks. <https://owasp.org/www-project-top-ten/> (2021). Accessed 16 Mar 2024
23. MITRE: Common Weakness Enumeration (CWE) - A Community-Developed List of Common Software and Hardware Weakness Types. <https://cwe.mitre.org/> (2024). Accessed 27 Mar 2024
24. Wallace, D., Fujii, R.: Software verification and validation: an overview. IEEE Software, vol. 6, no. 3, pp. 10–17 (1989). <http://ieeexplore.ieee.org/document/28119/>
25. PortSwigger Web Security: Burp suite documentation. <https://portswigger.net/burp/documentation/> (2024). Accessed 16 Mar 2024